THE AZURE AND AI SHOW · ONLINE · 7 NOV 2026

WHO APPROVED THAT.



HAMMED AJIBADE

AI AGENTS IN DELIVERY PIPELINES

A TRUE STORY

MY AGENT SUBMITTED THE SAME FORM TWICE.



Two runs. One identity.
Nobody could tell them apart.

Not even me.

NOW PUT IT IN THE PIPELINE

AGENTS ARE ALREADY SHIPPING CODE.



OPEN PULL REQUESTS

Code, config, dependencies.



RUN PIPELINES

Builds, tests, fixes for red runs.



SUGGEST RELEASES

And sometimes press the button.

ACCESS. THE QUICKEST WAY.

Option A: a human's token

THE AGENT IS HAMMED

Everything I can do. No end date.

Option B: a shared service account

THE AGENT IS SP-CI-SHARED

So is every other pipeline that uses it.

IT WORKS.

Until something goes wrong.

To every system downstream, the agent and the person look the same.

THE INCIDENT REVIEW

THREE QUESTIONS NOBODY CAN ANSWER.

1

WHICH ACTIONS WERE THE AGENT'S

2

WHO APPROVED THEM

3

HOW TO SWITCH IT OFF WITHOUT BREAKING THE REST

THE FIX

TREAT THE AGENT AS ITS OWN PRINCIPAL.

01

OWN IDENTITY

Scoped, expiring access. Never a person's.

02

APPROVAL GATE

In front of releases and production changes.

03

EVIDENCE

What it saw, did and was allowed to do.

04

REVOCATION

Drill it: one agent off in minutes. Nobody else rotates.

WALKTHROUGH

ONE CHANGE. FIVE STEPS.

1 PROPOSE

The agent opens a pull request for a fix.

2 CREDENTIAL

Its own identity, for this job, gone when the job ends.

3 APPROVE

Production waits for a named human.

4 RECORD

Evidence of what it saw and did.

5 REVOKE

Switch it off, and prove it stopped.

STEPS 1 AND 2: PROPOSE, WITH ITS OWN CREDENTIAL

DO MY WORK. DON'T BE ME.

BORROWED

acts as	hammed
can do	everything I can
expires	when I remember

ITS OWN

on behalf of	Hammed
carried by	fix-agent, run 7f3
allowed	open PR, deploy staging
production	waits for approval
expires	when the job ends

The work stays in my name. The agent just isn't wearing my face.

STEP 3: THE APPROVAL GATE

APPROVE THE ACTION, NOT THE AGENT.



The approver sees this diff, this plan, this target. If any of it changes, approve again.

STEP 4: EVIDENCE

RECORD WHAT IT SAW, DID AND WAS ALLOWED TO DO.

EXAMPLE RUN RECORD

holder	fix-agent, run 7f3
on behalf of	H. Ajibade
saw	PR diff, failing test log
allowed	open PR, deploy staging
approved by	lead, after diff + plan
did	deploy api 1.42 to production
way back	api 1.41 verified present
result	exit code 0, raw log kept

An agent's summary is a claim. The exit code is evidence.

Append-only. Readable by someone who wasn't there.

STEP 5: THE REVOCATION DRILL

PULL THE SWITCH ON PURPOSE.

01

REVOKE ONE AGENT

From outside it. Not by asking it to stop.

02

NEXT ACTION REFUSED

Try a deploy as that agent. It fails.

03

EVERYONE ELSE FINE

No shared secret to rotate. No pipeline breaks.

04

KEEP THE PROOF

The denial, with a timestamp, in the record.

If you've never pulled it, you don't have an off switch.

PART TWO

NOW ON AZURE.

What the docs support today, and where the gaps are.

AZURE: IDENTITY

NO SECRET TO STEAL.

PIPELINE OUTSIDE AZURE

WORKLOAD IDENTITY FEDERATION

Entra trusts a GitHub or Azure Pipelines token. No client secret stored.

AGENT ON AZURE COMPUTE

MANAGED IDENTITY

The platform holds the credential. You never see it.

PERMISSIONS

AZURE RBAC, SMALLEST SCOPE

One identity per agent. A role on one resource group, not the subscription.

```
subject: repo:org/app:environment:production
```

AZURE: APPROVAL

THE GATE LIVES OUTSIDE THE YAML.

AZURE PIPELINES

ENVIRONMENT APPROVALS AND CHECKS

Set by the resource owner, not the pipeline author. Approvers can be barred from approving their own runs. A bypass shows who bypassed.

GITHUB ACTIONS

ENVIRONMENT REQUIRED REVIEWERS

Self-review can be blocked. Environment secrets stay locked until a reviewer approves. Check your plan for private repos.

Plus Azure Policy with a deny effect: some things no identity in that scope can create.

AZURE: EVIDENCE

FOUR LOGS. ONE STORY.

ACTIVITY LOG

Control-plane changes and who made them. Kept 90 days; export to Log Analytics to keep longer.

ENTRA SIGN-IN LOGS

Service principal and managed identity sign-ins. Which agent got a token, and when.

RESOURCE LOGS

Data-plane reads, like a Key Vault secret. Off by default: turn on with a diagnostic setting.

THE PIPELINE RUN

Who approved, which checks passed, the raw logs and exit codes.

Tie them together with the run ID, or you have four logs and no answer.

AZURE: REVOCATION

REVOCATION HAS A CLOCK.

Delete the federated credential	No new token exchange, once the change propagates.
Remove the role assignment	Can take up to 10 minutes to take effect.
Tokens already issued	Default lifetime 60 to 90 minutes.
Continuous access evaluation	Workload identities: Graph only, not managed identities.
Key Vault secret expiry	Informational. Disable the secret to block reads.

So revoke at the gate too: a check the agent must pass before every consequential stage.

TAKE THIS TO WORK ON MONDAY

SIX CHECKS BEFORE PRODUCTION.

1. Its own identity. No person's token, no shared account.
2. Access scoped to one job, and it expires.
3. Production waits for a named approver who isn't the requester.
4. Every run records what it saw, did and was allowed to do.
5. Revoke this agent without rotating anyone else's credentials.
6. Pull the switch on purpose. Keep the proof.

WHO APPROVED THAT.

ANSWER WITH A RECORD,

NOT A GUESS.

The framework: github.com/ajibadedapo/agent-mandates

SLIDES

AGENT MANDATES

HAMMED AJIBADE

LINKEDIN.COM/IN/HAMMED-AJIBADE-010BB2116